

Smells na cadeia de fornecimento de software em projetos npm

Aplicado a aplicações React

Orientadora: Isabel Azevedo

Rafael Santos 1221267

DEI.ISEP

Licenciatura em Engenharia Informática

Índice

1. Introdução
2. Objetivos do trabalho
3. Outros trabalhos
4. Ferramentas existentes
5. Domínio do Problema
6. Iteração 1 e Iteração 2
7. Execução da ferramenta e resultados obtidos
8. Trabalho futuro
9. Referências

Introdução

- O uso crescente de dependências e bibliotecas de terceiros;
- Aumento dos ataques à Cadeia de fornecimento de *Software* (*Software Supply Chain*);
- Incidente de segurança da SolarWinds;

Objetivo do trabalho

- Estudo conceito de *Software Supply Chain Smells*;
- Analisar indicadores e riscos associados a dependências;
- Contribuir para a melhoria da segurança e manutenção de aplicações React;
- Permitir a detecção automática destes problemas;
- Validação e verificação da ferramenta através da análise de vários projetos;

Outros trabalhos

- *“Dirty-Waters: Detecting Software Supply Chain Smells”*
- *“What are Weak Links in the npm Supply Chain?”*
- *“Software Supply Chain Smells: Lightweight Analysis for Secure Dependency Management”*
- *“Dependency Smells in JavaScript Projects”*

Outros trabalhos

"Dirty-Waters: Detecting Software Supply Chain Smells"	"Software Supply Chain Smells: Lightweight Analysis for Secure Dependency Management"	"What are Weak Links in the npm Supply Chain?"	<i>"Dependency Smells in JavaScript Projects"</i>
Software Supply Chain Smells	Software Supply Chain Smells	Weak Link Signals	Dependency Smells
Dependency Smells	Dependency Smells		

Indícios de riscos nas dependências (*smells*)

Ferramentas existentes

Para gerar o SBOM:

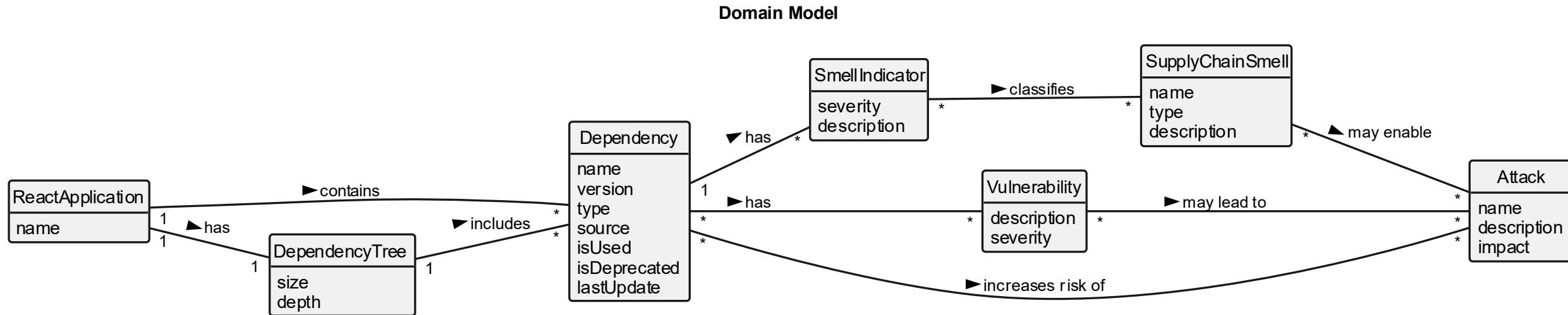
- CycloneDX
- cdxgen
- Syft

Para detetar *smells*:

- Dirty Waters;
- Depcheck;
- DependencySniffer;
- Snyk;
- Knip;
- OpenSSF Scorecard.

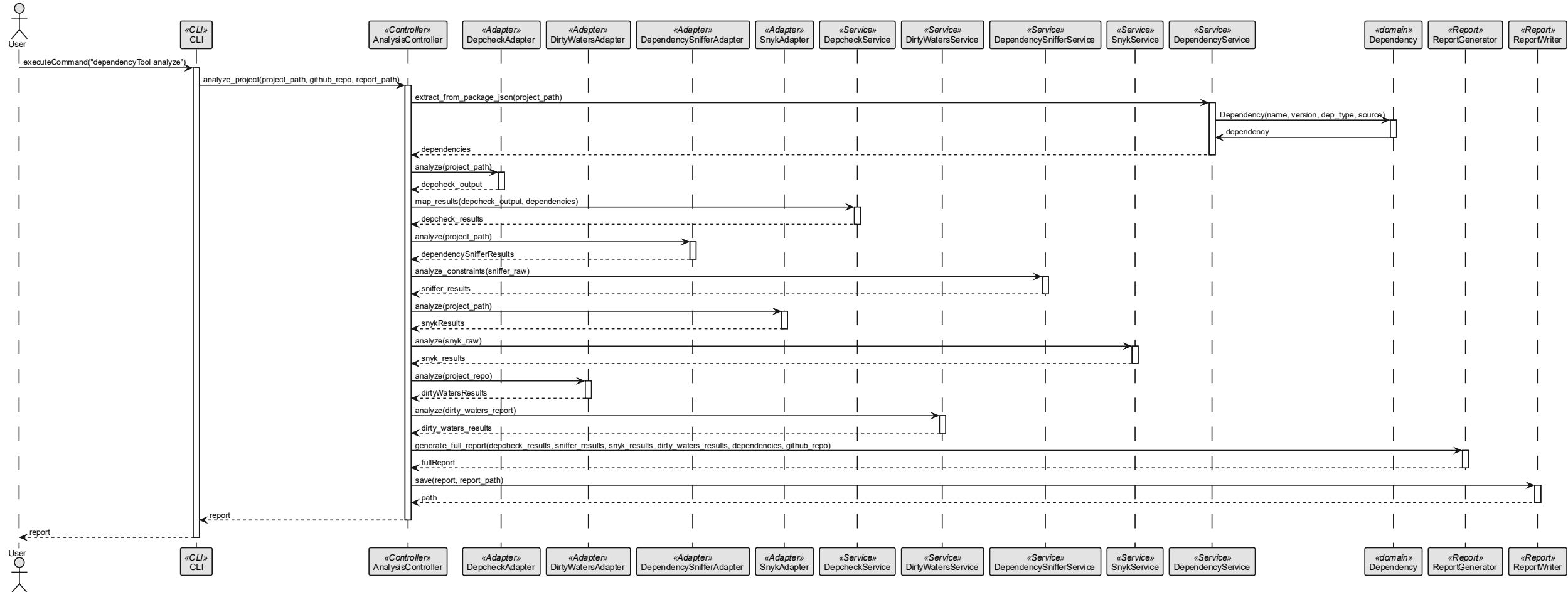


Domínio do problema

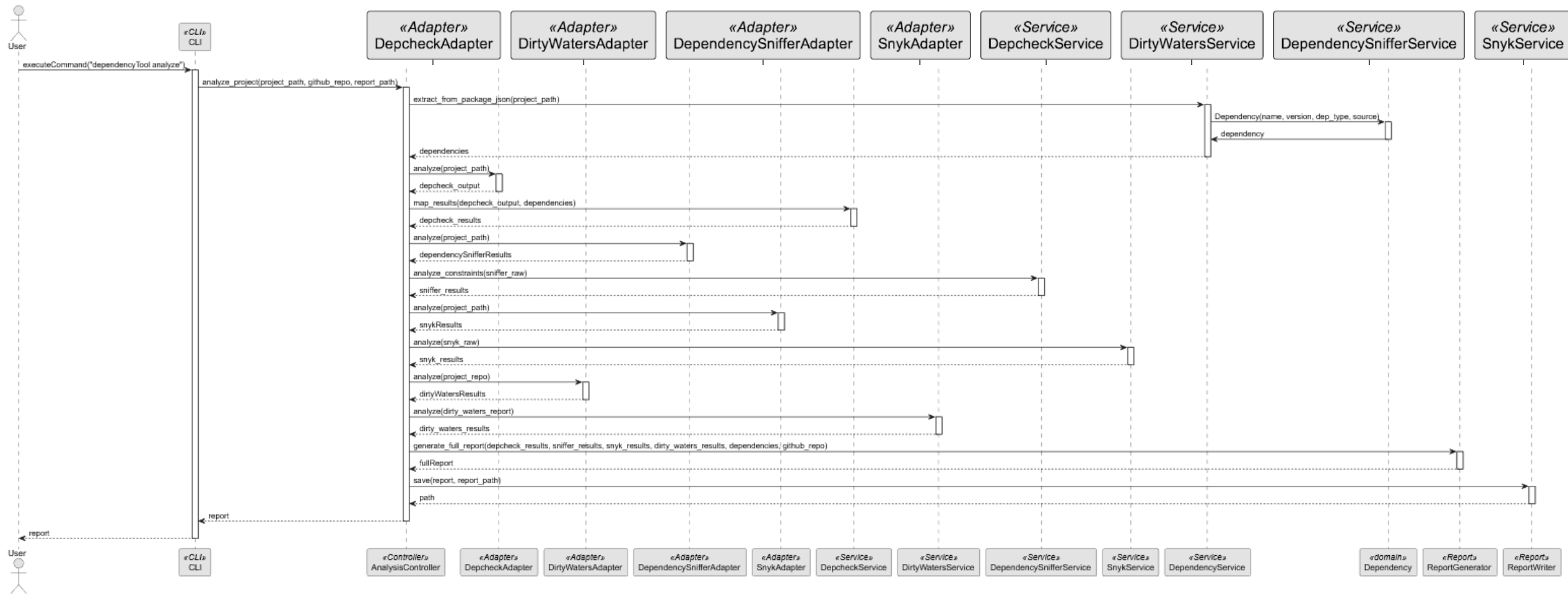


Iteração 1

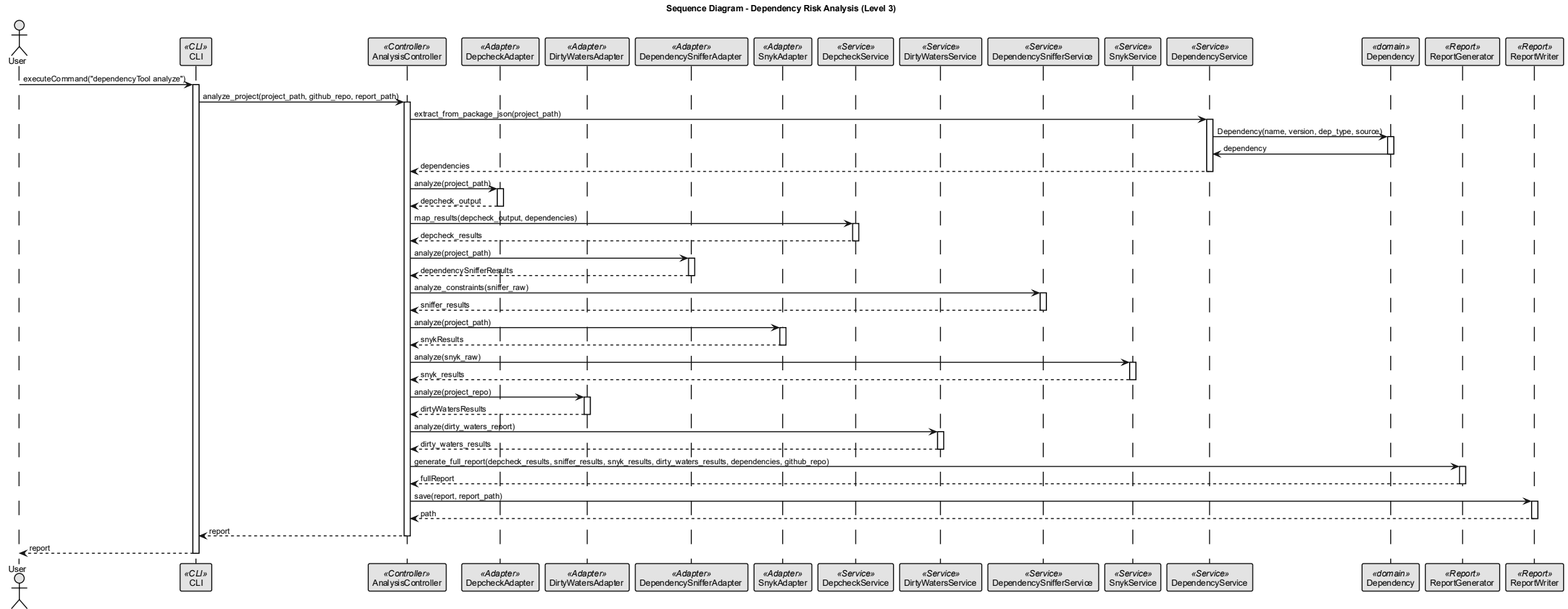
Sequence Diagram - Dependency Risk Analysis (Level 3)



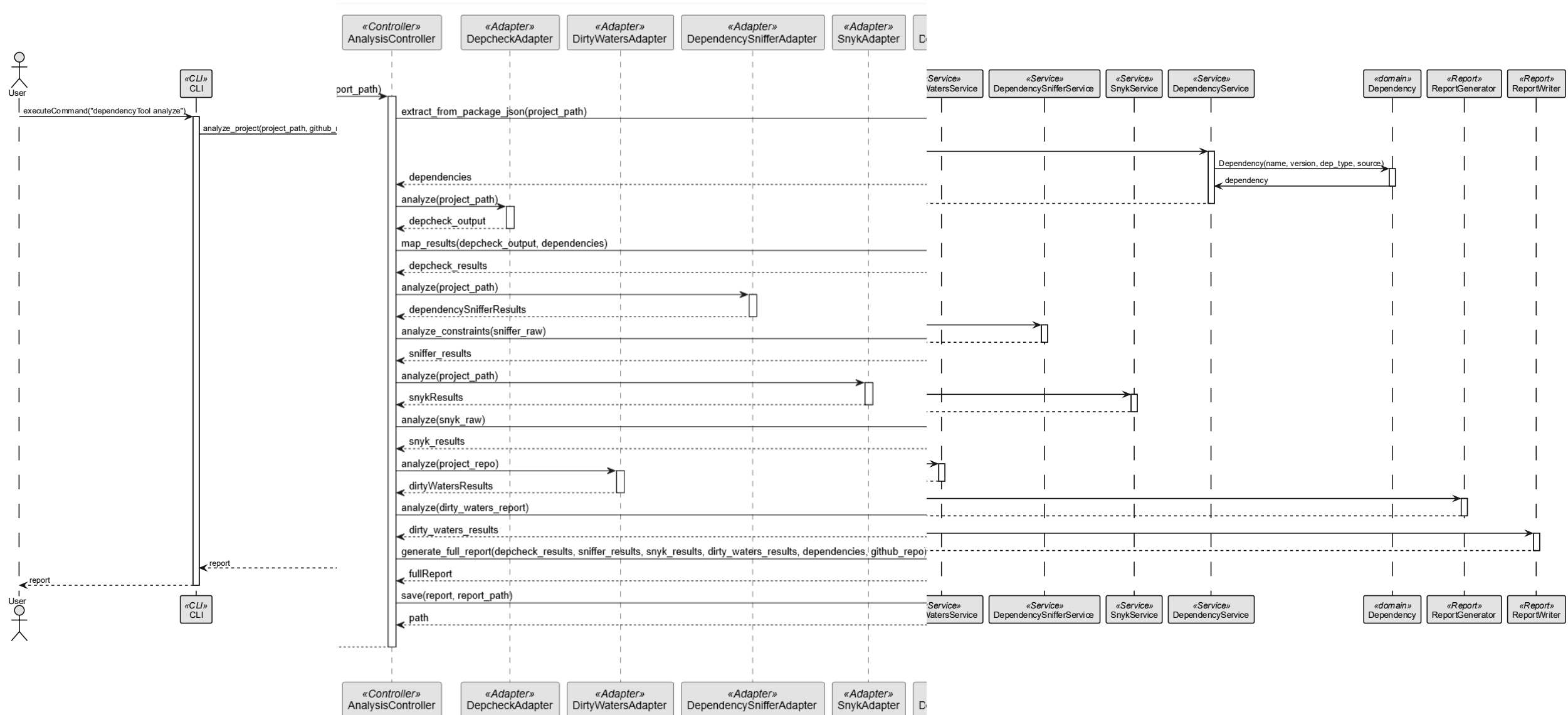
Iteração 1



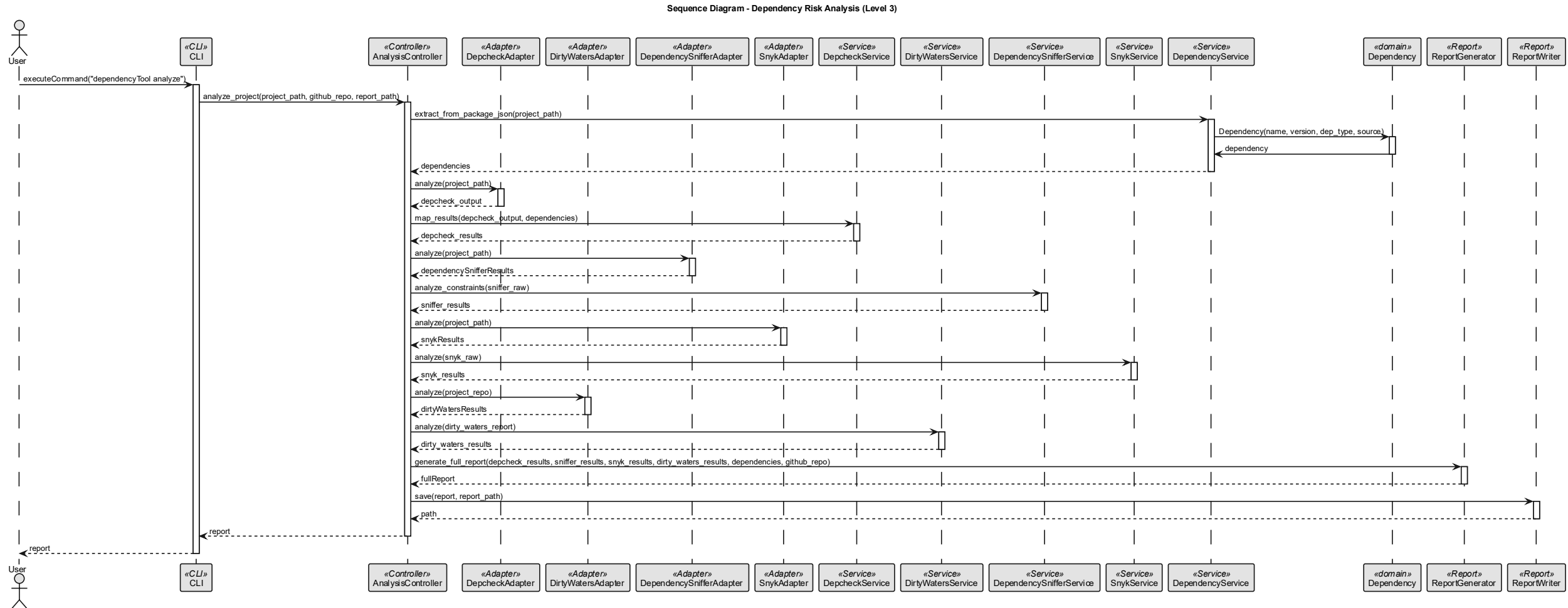
Iteração 1



Iteração 1

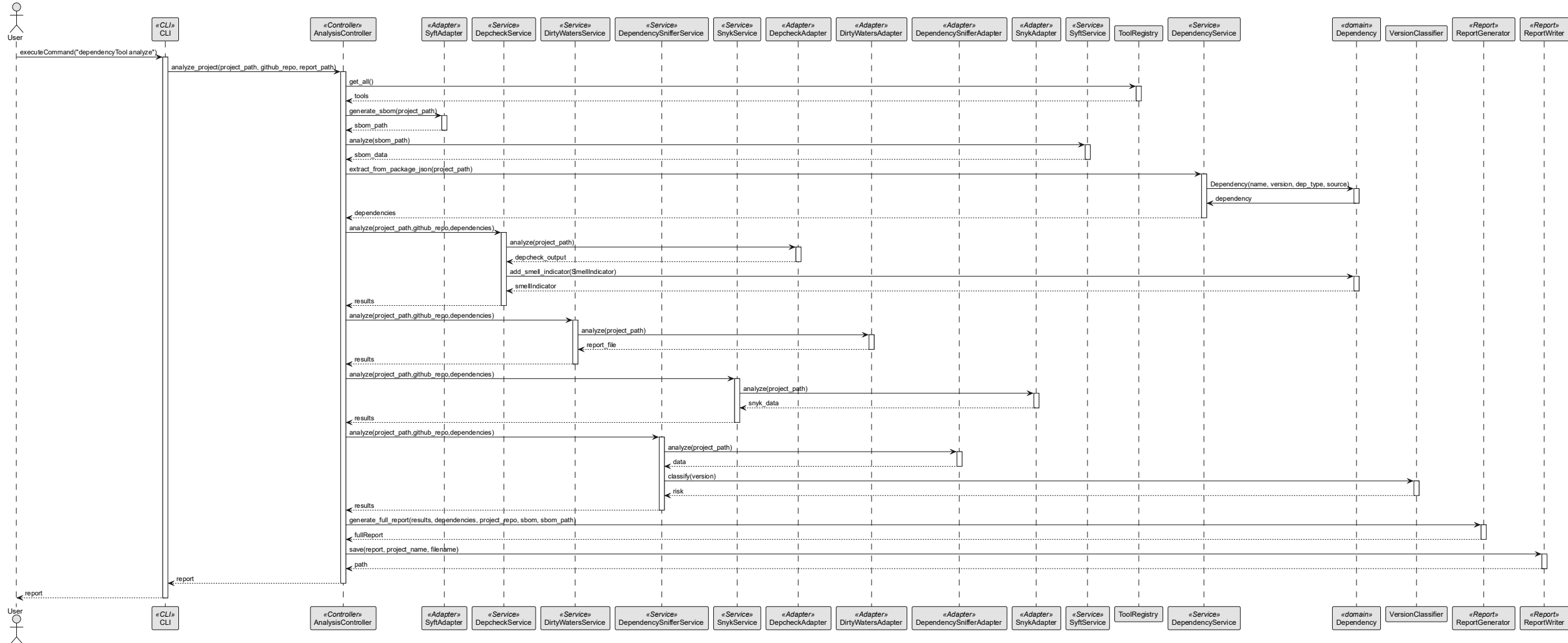


Iteração 1

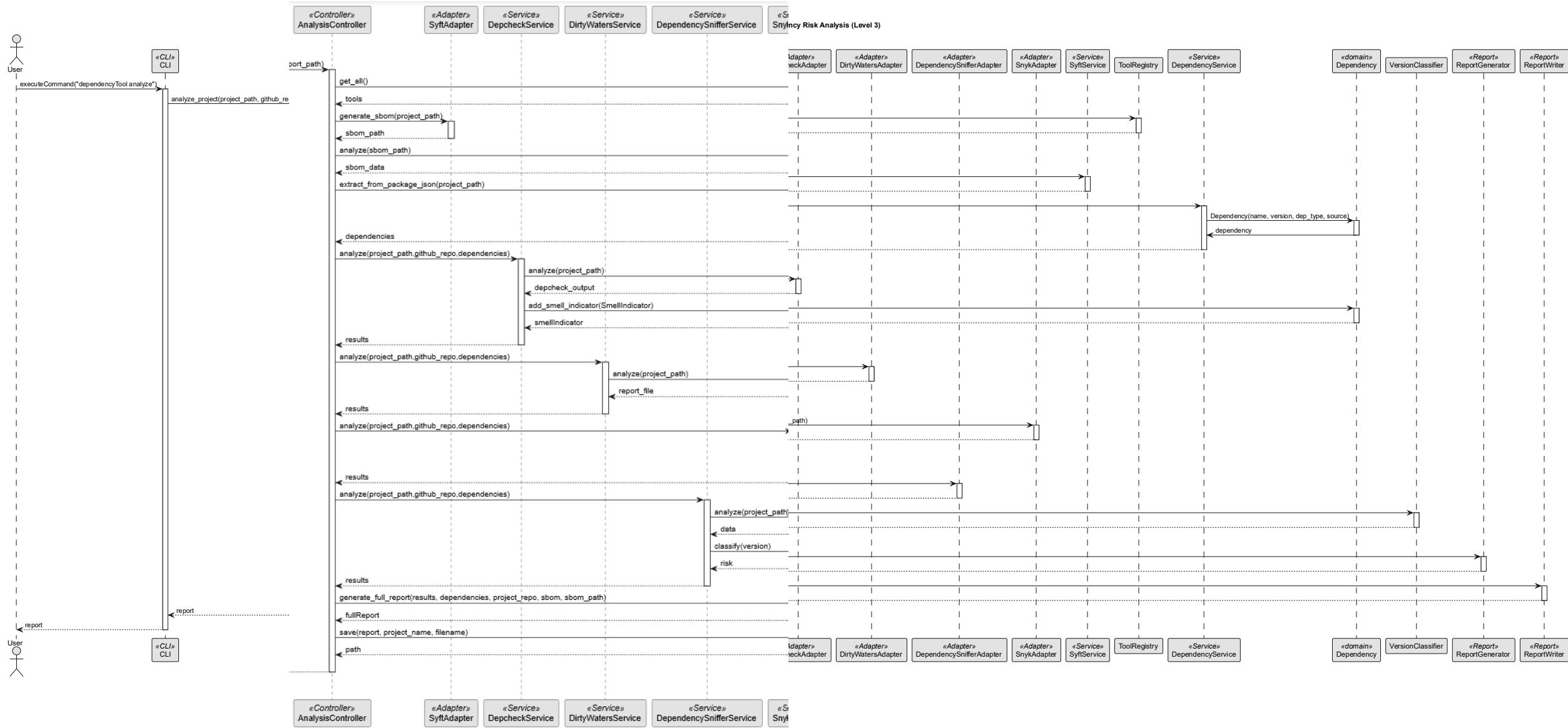


Iteração 2

Sequence Diagram - Dependency Risk Analysis (Level 3)



Iteração 2



Execução da ferramenta

- Cada ferramenta tem de estar instalada anteriormente;
- Exemplo de comando para executar a ferramenta:

```
dependencyTool analyze RafiLS/TaskReact  
--path  
"C:\Users\Rafael\Desktop\TaskReactVite"
```

```
check_source_code = true  
check_source_code_sha = true  
check_deprecated = true  
check_forks = false  
check_provenance = true  
check_code_signature = false  
check_aliased_packages = true  
  
[licenses]  
problematic_licenses = ["GPL", "AGPL", "UNKNOWN"]  
  
[version_smells]  
dangerous_versions = ["*", "latest"]  
  
unstable_prefixes = [  
    "^0.",  
    "~0."  
]  
  
normal_prefixes = [  
    "^",  
    "~"  
]  
  
high_risk_label = "HIGH"  
medium_risk_label = "MEDIUM"  
low_risk_label = "LOW"  
safe_label = "SAFE"  
unknown_label = "UNKNOWN"
```


✓ **DEPENDENCYTOOL**

- > __pycache__
- > .idea
- > .pytest_cache
- > .venv
- > cache
- > dependency_tool.egg-info
- > Docs

✓ save_reports

- > Abbrev
- > axios
- > create-react-app
- > NGOWorld
- > react-example

✓ src

- > __pycache__
- > adapters
- > config
- > controllers
- > domain
- > report
- > services

🔗 __init__.py

🔗 cli.py

> tests

🔖 .gitignore

⚙️ config.toml

👤 LICENSE

≡ pytest.ini

① README.md

🔗 setup.py

○ (dirty_env) PS C:\Users\Rafael\Desktop\Estágio\DependencyTool>

Smells encontrados

- Request;
- left-pad;
- supertest;

Unused dependencies (9)

- request
- node-uuid
- left-pad
- uuid
- @types/react
- @types/react-dom
- depcheck
- jest
- supertest

- Tough-cookie

Transitive dependencies (6)

- follow-redirects (via taskreactvite@0.0.0 > axios@1.13.5 > follow-redirects@1.15.11)
- form-data (via taskreactvite@0.0.0 > request@2.88.2 > form-data@2.3.3)
- form-data (via taskreactvite@0.0.0 > axios@1.13.5 > form-data@4.0.5)
- qs (via taskreactvite@0.0.0 > request@2.88.2 > qs@6.5.5)
- tough-cookie (via taskreactvite@0.0.0 > request@2.88.2 > tough-cookie@2.5.0)
- uuid (via taskreactvite@0.0.0 > request@2.88.2 > uuid@3.4.0)

Smells encontrados

Ativação e desativação de alguns *smells* no ficheiro de configuração.

```
check_source_code = true
check_source_code_sha = true
check_deprecated = true
check_forks = false
check_provenance = true
check_code_signature = false
check_aliased_packages = true
```

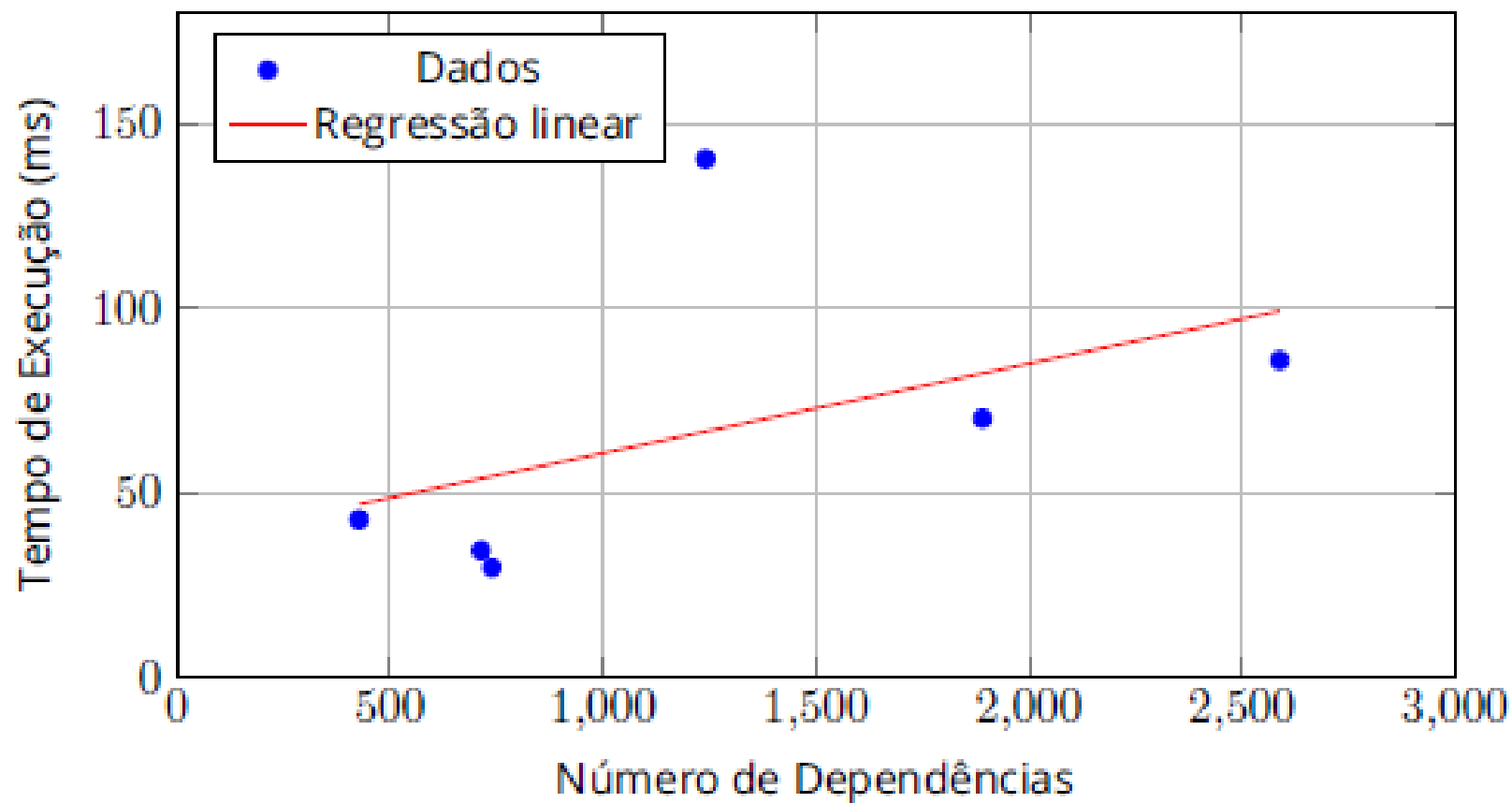
Other Smells Detected

- missing_source_code: 2
- repo_404: 4
- inaccessible_sha: 4
- deprecated: 16
- no_code_signature: 0
- invalid_code_signature: 0
- forks: 0
- aliased: 0

Resultados obtidos

Repositório	Número de Dependências	Tempo de execução (s)
RafiLS/TaskReact	739	29.95
axios/axios	714	34.54
ngoworldcommunity/NGOWorld	1891	70.25
Njong392/Abbreve	427	42.95
yubo/react-example	1241	140.44
react/create-react-app	2589	85.98

Resultados obtidos



Trabalho futuro

- Permitir integração contínua, para gerar relatórios ocasionalmente e avaliar a evolução de um projeto;
- Acrescentar novas ferramentas que avaliem outros *smells*.
- Aumentar o número de *smells* avaliados.



Referências

- chains-project (2025), Dirty-Waters, <https://github.com/chains-project/dirty-waters>
- DataDog (2024), *dd-dependency-sniffer*, <https://github.com/DataDog/dd-dependency-sniffer>
- depcheck (2024), depcheck, <https://www.npmjs.com/package/depcheck>
- Fortinet (2025), Ataque à cadeia de suprimentos da SolarWinds, <https://www.fortinet.com/resources/cyberglossary/solarwinds-cyber-attack>
- JSR (2026), @cyclonedx/cdxgen, <https://jsr.io/@cyclonedx/cdxgen>
- Liu, R., Bobadilla, S., Baudry, B. e Monperrus, M. (2022), "Detecting Software Supply Chain Smells", *International Conference on Software Engineering*, Pittsburgh, USA, May
- Liu, R., Bobadilla, S., Baudry, B., & Monperrus, M. (2025), "Dirty-Waters: Detecting software supply chain smells", *International Conference on the Foundations of Software Engineering*, Porto Alegre, Brazil, Jun.
- OWASP Foundation (2026), *CycloneDX: Open Standard for Software Bill of Materials (SBOM)*, <https://owasp.org/www-project-cyclonedx/>
- SoftwareSeni (2026), Software supply chain security: From regulatory compliance to incident response, <https://www.softwareseni.com/software-supply-chain-security-from-regulatory-compliance-to-incident-response/>